

SECURITY OPERATIONS CENTER — HOME LAB

# Phase 1

## Flat Layer-2 SOC Detection Lab

Detection → Evidence → Visualization

# What was the goal?

Can the SOC see an attack from multiple angles at once?

-  **Network** traffic crossing the wire
-  **Endpoint** what happens inside a host
-  **Availability** is the infrastructure up & collecting
-  **DFIR / Forensic** deep-dive after an alert
-  **Deception** who touched a system they shouldn't

# Phase 1 architecture — flat by design

```
FLAT  LABNET  10.10.10.0/24
(no gateway / router / firewall)
```

```
attacker .40 ---+
throwaway  ----+
honeypot .70 ---+----> SENSOR (Suricata + Zeek, promiscuous tap)
wazuh .20  -----+
zabbix    -----+
velociraptor ---+
grafana   -----+
```

Wazuh = central SIEM

Grafana = analyst view

# Why these VMs?

## Wazuh

SIEM / security brain

## Sensor

Suricata + Zeek

## Zabbix

Availability

## Velociraptor

DFIR

## Grafana

Visualization

## Throwaway

Victim

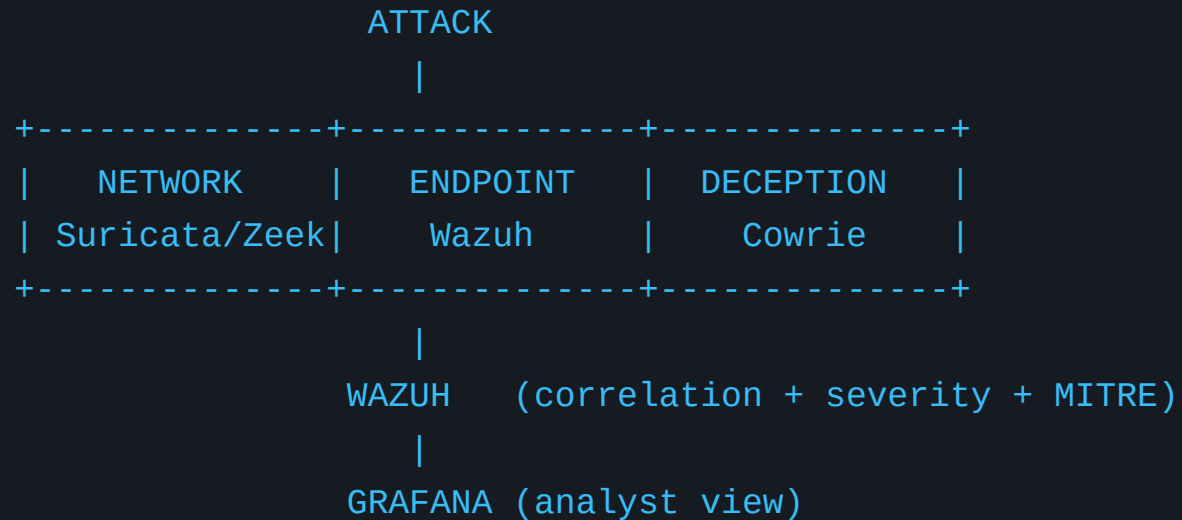
## Honeypot

Deception (Cowrie)

## Attacker

Attack generation

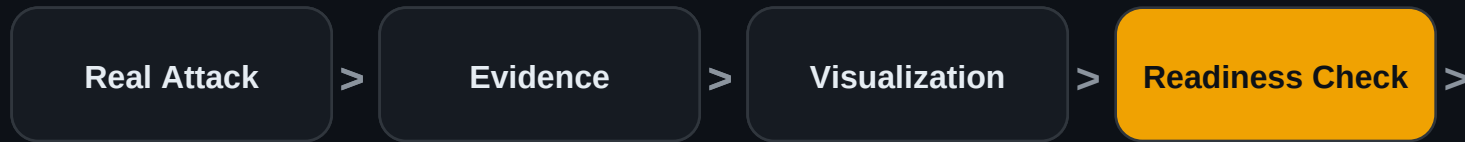
# How the planes work together



Availability -> Zabbix

Deep dive -> Velociraptor

# From build to verified detection



Installation is NOT proof. The sensor had to prove it sees traffic  
(two-window tcpdump + ping) before any attack counted as a valid test.

# Real attacks



## ARP MITM

MITRE T1557.002



## MAC Flooding

MITRE T1498.001



## Rogue DHCP

MITRE T1557.003



## SSH Brute Force

MITRE honeypot / T1110



## Traffic Sniffing

MITRE T1040



## Malware Delivery — EICAR

MITRE T1204

# What did the SOC actually detect?

**9,600+**

Suricata alerts

**16K+**

Zeek connections

**122**

High severity

**3**

Critical

**1,541**

Auth events

**309**

Incidents ( $\geq 6$ )

# Network visibility

## Suricata (detection)

- Scans
- LFI attempt on /etc/passwd
- ICMP activity
- SSH scanning
- HTTP activity

## Zeek (context)

- Connections
- DNS
- HTTP
- TLS
- SSH
- Hunting context

# Endpoint & deception

## Wazuh (endpoint)

- Authentication
- Sudo / PAM
- MITRE ATT&CK ranking
- Valid Accounts, Brute Force...

## Cowrie (honeypot)

- SSH session captured
- Commands typed
- Attacker source IP
- Full attacker interaction

*Attacker 10.10.10.40 hit SSH :22 -> Cowrie logged every command in the fake shell.*

# FIM + VirusTotal

File dropped in /tmp

```
|  
Wazuh FIM (realtime)  
|  
file hash  
|  
VirusTotal API  
|  
Malicious verdict -> rule 87105
```

**64/67**

**ENGINES MALICIOUS**

EICAR test — full chain proven

# Cyber Kill Chain coverage

|                         |                   |
|-------------------------|-------------------|
| ● Reconnaissance        | detected          |
| ● Weaponization         | N/A - off-network |
| ● Delivery              | detected          |
| ● Exploitation          | detected          |
| ● Installation          | detected          |
| ● Command & Control     | detected          |
| ● Actions on Objectives | detected          |

# 6/7

## STAGES DETECTED

Weaponization = unobservable

# How the analyst sees it

**01 Overview**

**02 Incidents / Triage**

**03 Network**

**04 Endpoint / File**

**05 Health**

EVERY PANEL PRIORITIZES

**TIME**

**SOURCE**

**DESTINATION**

**ACTION**

**SEVERITY**

# Phase 1 — PASSED

---

- 5 detection planes deployed
- Real attacks executed live
- Genuine evidence captured at every plane
- FIM + VirusTotal added and validated
- 6 / 7 Cyber Kill Chain coverage
- 5 analyst-first Grafana dashboards
- Snapshot baseline created

# What comes next?

- 1. Time synchronization (align Wazuh + Zabbix)
- 2. FIM expansion to high-value directories
- 3. Suricata tuning (cut informational noise)
- 4. Phase 2 — routing & segmentation

Flat Network > Routing > Segmentation > Firewall > Containment

Phase 1 establishes the visibility foundation. Next phases build controls on top.